

Q1 OSINT - Reconnaissance using the Harvester
against tesla.com

R. Akhen Abislet

192311034

Methodology :

the Harvester -d tesla.com -b all -f 500 -F fella
-all.html

the Harvester -d tesla.com -b cvtsh

the Harvester -d tesla.com -b bing

the Harvester -d tesla.com -b linkedin

the Harvester -d tesla.com -b shodan

Sample output :

the Harvester 4.4.4

[*] target : tesla.com

[*] searching cvtsh - - -

[*] searching bing - - -

[*] searching linked in - -

[*] searching shodan - - -

[*] Emails found : 3

press@tesla.com

media@tesla.com

careers@tesla.com

[*] Hosts Found: 8

shop.tesla.com: 29.32.238.X

ix.tesla.com: 104.16.85.X

digitalssels.tesla.com: 151.101.2.X

api.tesla.com: 104.16.85.X

[*] linkedin people Found: 6

Recruiter - talent Acquisition

Site Reliability Engineer

Security Engineer.

2. Nikto - web scan on testphp.vulnweb.com

Steps:-

1. Run Nikto against the target web server.
2. Review Flagged Files, Methods, and headers.

3. Dig - DNS Enumeration on zone transfer. com

Steps:-

1. Query standard DNS records
2. Identify authoritative name servers
3. Attempt a Zone Transfer (AXFR)

Input:-

dig zone transfer. me A

dig zone transfer. me mx

dig zone transfer. me ns

dig zone transfer. me + short

dig zone transfer. me @ns2tml.digi.ninja.

Output:-

zone transfer. me. 7200 IN A 5.196.105.14

zone transfer. me. 300 IN MX 0 ASPMX.L.GOOGLE.
com.

zone transfer. me. 300 IN NS ns2tml.digi.ninja.

zone transfer. me. 300 IN NS ns2tm2.digi.ninja.

Input:

nikto -h http://test.php.vulnweb.com

Output:-

+ Server: nginx/1.19.0

+ /! Retrieved x-powered-by header:

PHP/5.6.40

+ /! login.php: Admin login page / section found.

+ /cvs/entries: cvs entries file is accessible,

revealing directory listings.

+ /admin/: This might be interesting

+ Options: Allowed HTTP Methods: GET, HEAD, POST, OPTIONS, TRACE.

+ TRACE: server allows TRACE, indicating xst is possible.

+ images /! Directory indexing found.

+ 7530 request: 0 errors) and 8 items reported

4. Enum4linux - SMB Enumeration on 192.168.1.100

Steps:-

1. Run Enum4linux in full mode against the target
2. Check for null session, users, shares, password policy.

Input:-

Enum4linux -a 192.168.1.100

Output:-

Users:-

Index: 0x3e8 RID: 0x3e8 Account: administrator

Index: 0x3e9 RID: 0x3e9 Account: guest

Index: 0x3ea RID: 0x3ea Account: jdoe

Index: 0x3eb RID: 0x3eb Account: svc-backup

Shares:-

Admins: Disk Remote Admin

C\$ Disk Default share

public Disk company-wide file share

5. Netcat - Banner grabbing on scanme.nmap.

Org.

Steps.

1. Connect to open TCP ports
2. Record service banners / headers returned

Input:-

nc -v scanme.nmap.org 22

printf 'HEAD / HTTP/1.0\r\nHost: scanme.'

nmap.org\r\n\r\n' | nc -v scanme.

nmap.org 80

Output:-

connections to scanme.nmap.org 22 port [tcp/ssh]
Succeeded.

SSH - 2.0 openssh - 6.6.1 p1 ubuntu - 20.04
2.13

connections to scanme.nmap.org 80 port [tcp/
http] succeeded.

HTTP/1.1 200 OK